

DevSecOps: Static Application Security Testing Using Snyk and SonarQube

Applications are tested rigorously for their functionality by developers, who spend a lot of time in doing so. Static Application Security Testing (SAST) is an important step or perhaps the very first step in the DevSecOps pipeline. It is the analysis and testing of the static code of complex projects. SAST is not to be confused with normal code testing as it includes security, too, in its acronym. The focus of this article is SAST and how it can be implemented using open source tools like Snyk and SonarQube.



SAST gives a detailed analysis of the code and a list of all the bugs that might not be obvious but are making an application vulnerable. It is followed by other testing phases where the security of the project is continuously checked.

Why Snyk and SonarQube?

SAST can be done by plenty of tools, so why Snyk and SonarQube? Snyk helps in detecting bad dependencies and monitors them continuously. Active suggestions, automatically sending pull requests for dependency checks, real-time alerts on vulnerabilities, and managing the dependency tree is easy with Snyk. On the other hand, SonarQube takes input as files and checks them on different parameters

like unit tests, duplicated code segments, bugs, coding standards, comments, complexity, etc. It then stores the calculated metric in a database and displays it in a dashboard. SonarQube is scalable and can support many languages. Let us dive deep into both these tools.

SAST with Snyk

According to *Snyk.io*, Snyk is used by various tech giants like Google, Intuit, Salesforce, MongoDB, etc. You will love using Snyk since it provides the bug list and tells the ways to fix them. It has a strong and rich database of vulnerabilities that it uses. It supports various languages too. So, write in any language, and Snyk will be there to help you with SAST. Snyk is available as an

open source tool and has commercial editions too. We have used the open source version of Snyk in this article. Let's move on to installations and ways to use Snyk.

We are using Jenkins and Docker in some places. We can get the security of our static applications tested using Snyk, either by using it as a web application that runs in a browser or by installing it and running it with Jenkins as a plugin. The first way is easy. All you have to do is go to *Snyk.io* and create an account or login if you already have one. It will ask the location of your code, as shown in Figure 1. As the code is on GitHub, select it. The project we are testing here is 'Classroom Management System for IIT-B', and is written in Java using the Spring Boot Framework. The project allows professors to request for a classroom of their choice according to time, strength of students, projectors and plugs required, etc. These requests are accepted or rejected by the administrator. This open source project is available on GitHub at <https://github.com/shriyakabra97/ClassroomManagementSystem>.

After selecting the source code location (GitHub in our case), it will ask you to enter your GitHub credentials and select the project